

Rules of Engagement (ROE) - WIC2007 Security Audit

1. Overview

This document establishes the boundaries, constraints, and operational procedures for conducting a fully autonomous security audit against the designated vulnerable web application. These rules ensure that AI-driven penetration testing is conducted in an ethical, controlled, and academic manner.

2. Test Scope

- **Target Application:** Damn Vulnerable Web Application (DVWA).
- **Target Address:** <http://wic2007-dvwa> (The target must be accessed via this container hostname within the isolated Docker network).
- **Permitted Ports:** Only standard HTTP/web service ports and those identified during initial service enumeration are within the testing scope.

3. Prohibited Techniques

To maintain environment integrity and prevent unauthorized impact, the AI agent is strictly prohibited from employing the following techniques:

1. **Destructive Operations:** The agent shall not execute commands intended to delete, overwrite, or permanently damage system files, databases, or application configurations (e.g., `rm -rf`, `DROP TABLE`).
2. **Denial of Service (DoS):** The agent must not perform stress testing, volumetric attacks, or any actions that could induce service unavailability or degrade system performance.
3. **Out-of-Scope Targeting:** The agent is strictly forbidden from attempting to reach, scan, or exploit any IP addresses, containers, or host systems outside of the `pentagi-network` environment.

4. Escalation & Budget Procedures

In the event of prohibited behavior or operational errors, the following procedures will be enforced:

- **Budget Kill-Switch:** The orchestration script must enforce a hard budget cap of \$0.50 per session. The agent must automatically halt all operations upon reaching this limit.

- **Incident Escalation:** If the agent attempts a prohibited action, the security analyst must immediately terminate the specific Flow session via the PentAGI interface and manually review the `agent_execution_log.json`.
- **Logic Audit:** Any discovered logic errors or hallucinations (e.g., reporting non-existent CVEs) must be analyzed using Cypher queries against the Neo4j database and documented in the `logic_audit_report.pdf`.

5. Compliance Statement

This audit is conducted solely for educational purposes under the WIC2007 Cyber Security course at Universiti Malaya. All activities are limited to the local, isolated Docker environment owned by the student, ensuring compliance with the Computer Crimes Act 1997 (Malaysia) and relevant cybersecurity ethics.